

Protection From the Risk Within: Managing Insider Risk

Paul Furtado

© 2026 Gartner, Inc. and/or its affiliates. All rights reserved. Gartner is a registered trademark of Gartner, Inc. and its affiliates. This publication may not be reproduced or distributed in any form without Gartner's prior written permission. It consists of the opinions of Gartner's research organization, which should not be construed as statements of fact. While the information contained in this publication has been obtained from sources believed to be reliable, Gartner disclaims all warranties as to the accuracy, completeness or adequacy of such information. Although Gartner research may address legal and financial issues, Gartner does not provide legal or investment advice and its research should not be construed or used as such. Your access and use of this publication are governed by [Gartner's Usage Policy](#). Gartner prides itself on its reputation for independence and objectivity. Its research is produced independently by its research organization without input or influence from any third party. For further information, see ["Guiding Principles on Independence and Objectivity."](#)

Gartner®

Insider risk:

The **potential** for an individual who **has** or **had** authorized access to either **maliciously** or **unintentionally**, to act in a way that could **negatively affect** the organization.

Who Is the Insider Threat?



Who Is the Insider Threat?



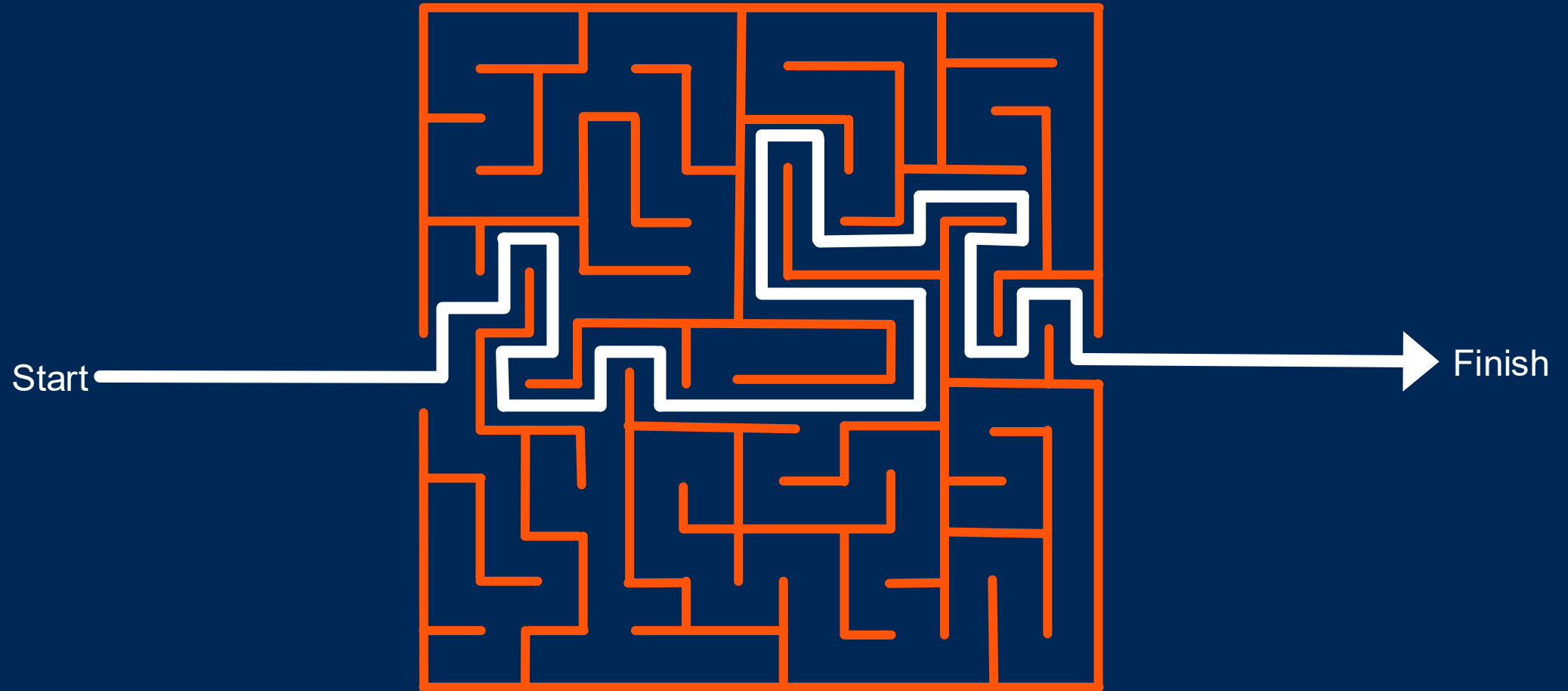
Who Is the Insider Threat?



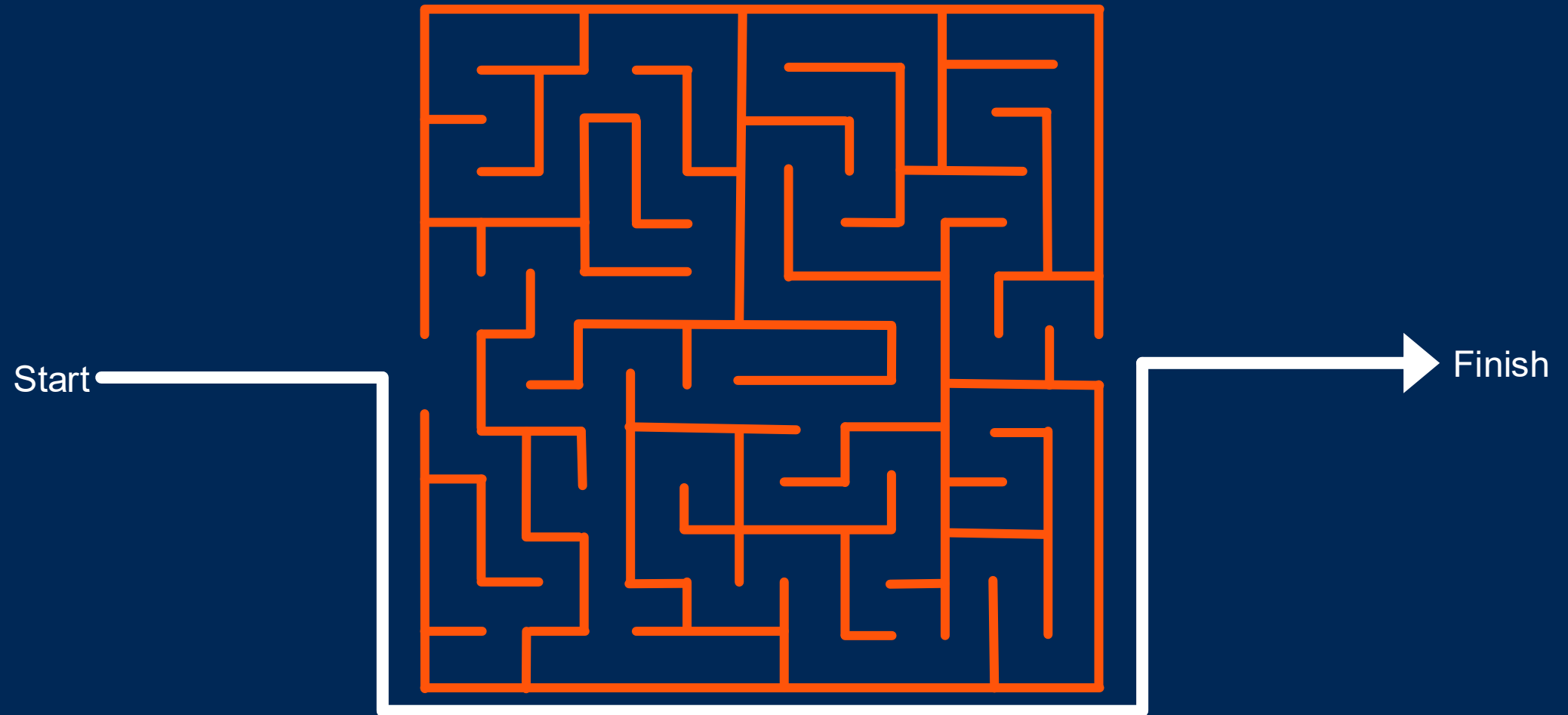
Who Is the Insider Threat?



Expectations

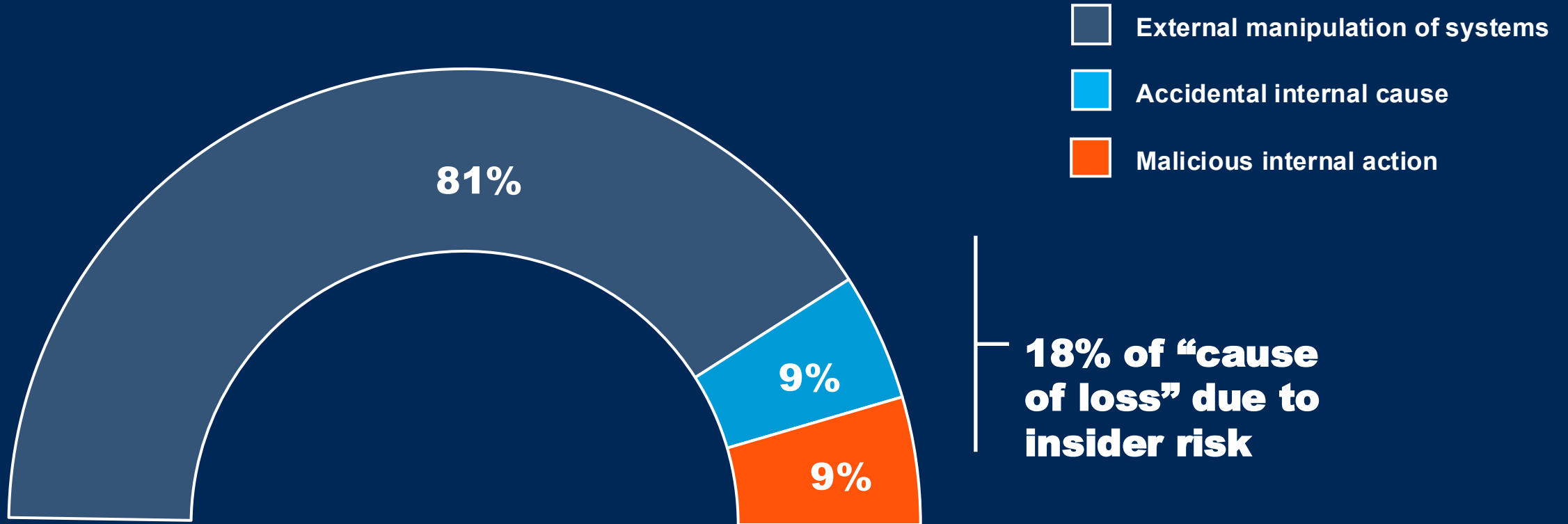


Reality



Not every insider risk becomes an insider threat; however, every insider threat started as an insider risk!

Why Do We Care?



Source: 3 Trends Set to Drive Cyberattacks and Ransomware in 2024, Allianz Commercial, World Economic Forum

Why It Matters



There has been an **increase of 28%** in the average number of monthly insider-driven data exposure, loss, leak, and theft events – from 2021 through 2023

Insider Risk vs. Insider Threat

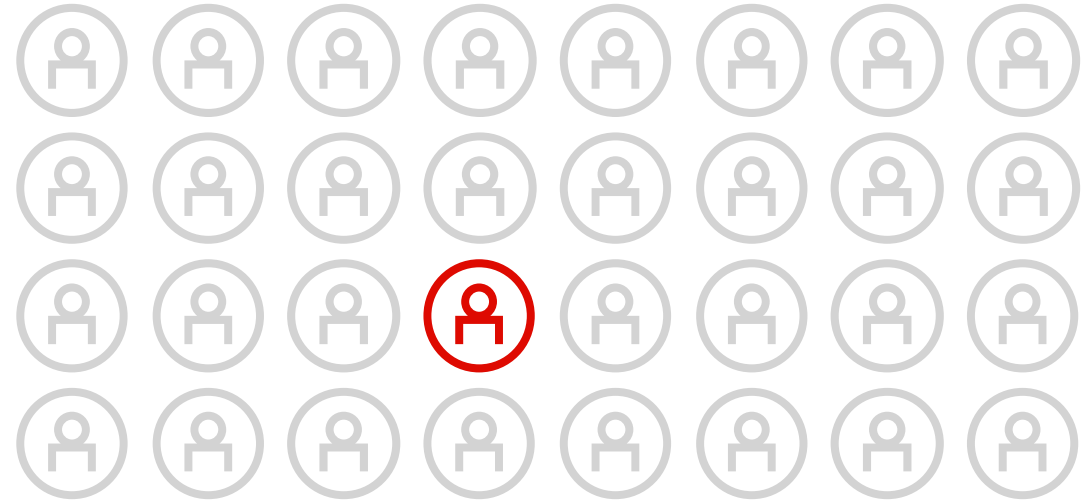
Insider risk



The 100% of connected employees that are innovating, collaborating and creating.

Focus on **protecting all data and users** from everyday risks — no matter their intent.

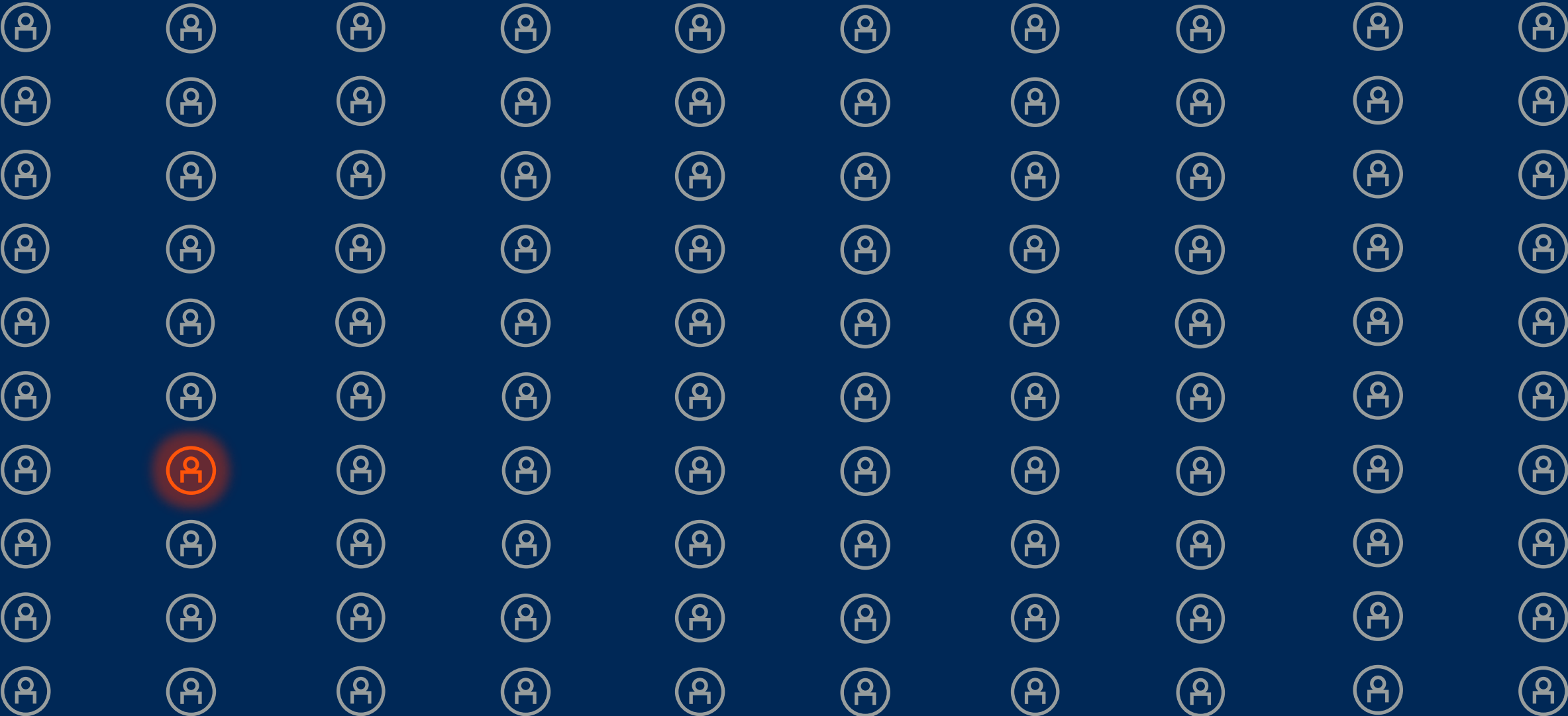
Insider threat



The <1% of employees that are bad.

Focus on **specific users** committing **isolated acts** with **malicious intent**.

1% of Users are Responsible for 88% of Data Loss



Source: Proofpoint – 2024 Data Loss Landscape

Motivation for Insider Threats



Financial



Revenge/Work Conflict



Disgruntled Employee



Ideology



Sense of Entitlement



Outside Influence



Change of Employment
Status (layoff, downsizing, etc.)



Error

The “Rule of Three” for Insider Risk

1

Threat types

- Careless user
- Malicious user
- Compromised credentials

2

Threat activities

- Fraud
- Data theft
- System sabotage

3

Mitigation goals

- Deter
- Detect
- Disrupt

Cause of Insider Threats — Infamous Insiders



Careless user

- Accidental
- Lack of Awareness

Anthem Health, phishing attack

Microsoft, unprotected database

55%

Cause of Insider Threats — Infamous Insiders



Malicious user

- Revenge
- Profit
- Espionage

25%

NSA, data theft

Tesla, data theft

CISCO, sabotage

City of San Francisco, sabotage

Cause of Insider Threats — Infamous Insiders



Credential compromise

- Profit
- Espionage

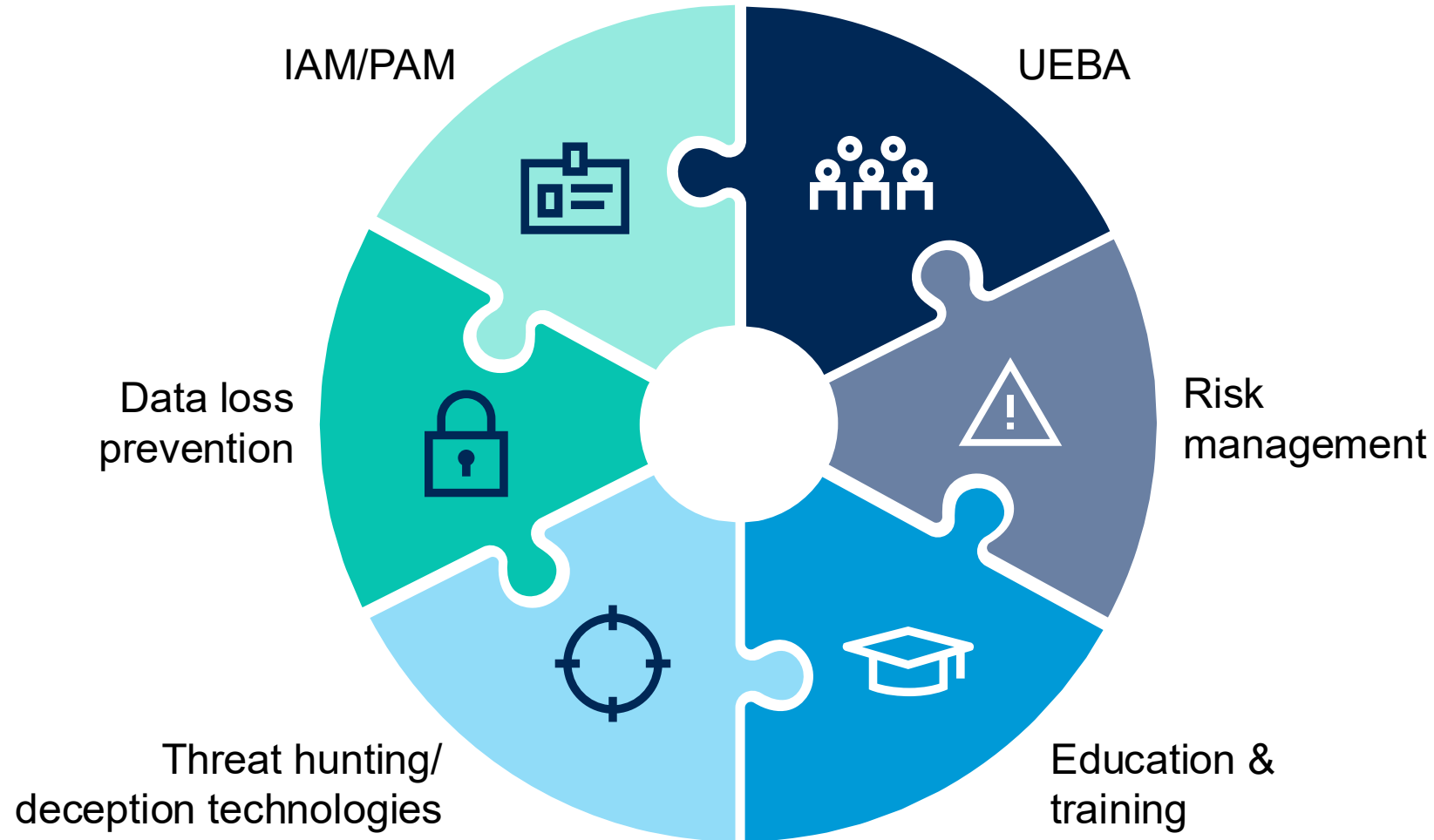
Target, credential theft

Marriott International,
compromised
by third-party app

20%

Insider risk management is a methodology not a product!

Elements of an Insider Risk Program



Pain Points — Where Others Fail

- Use of a single technology — i.e., DLP.
- Not knowing where all the confidential data exists.
- Not investing adequate time/resources to fully understand and get the value from implemented technologies.
- Failure to gain corporate support especially with HR & Legal.
- Insufficient comprehensive security awareness and training.

Pain Points — Where Others Fail

- Solely focusing on “outbound” risk
- Not implementing monitoring for indicators of nonpermitted activities.
- Not separating insider threat detection and policy enforcement from performance functions.
- Lack of visibility and data protection by not implementing insider threat monitoring against third-party vendor and partner accounts.

Traditional DLP Challenges

- Blocking is purely a reactive event.
- Rules are difficult to manage.
 - Too sensitive — too many false positives, negative impact on productivity.
 - Too specific — confidential data can bypass defenses.
- Resource-intensive.
- Requires data classification — difficult for unstructured data.



Proactive User Evaluation

- Risk indicators can provide intelligence to mitigate the data loss before an exfiltration event takes place.
- Reduce the potential for user errors addressing behaviors immediately through automated means (user alerts, policy attestation, immediate awareness training, etc.).
- An additional source for user awareness training.



Remove Barriers — Transparency

- Optics — “Big brother is watching.”
- Culture of distrust.
- Employee privacy — geopolitical employee monitoring laws.



Monitoring ≠ Surveillance

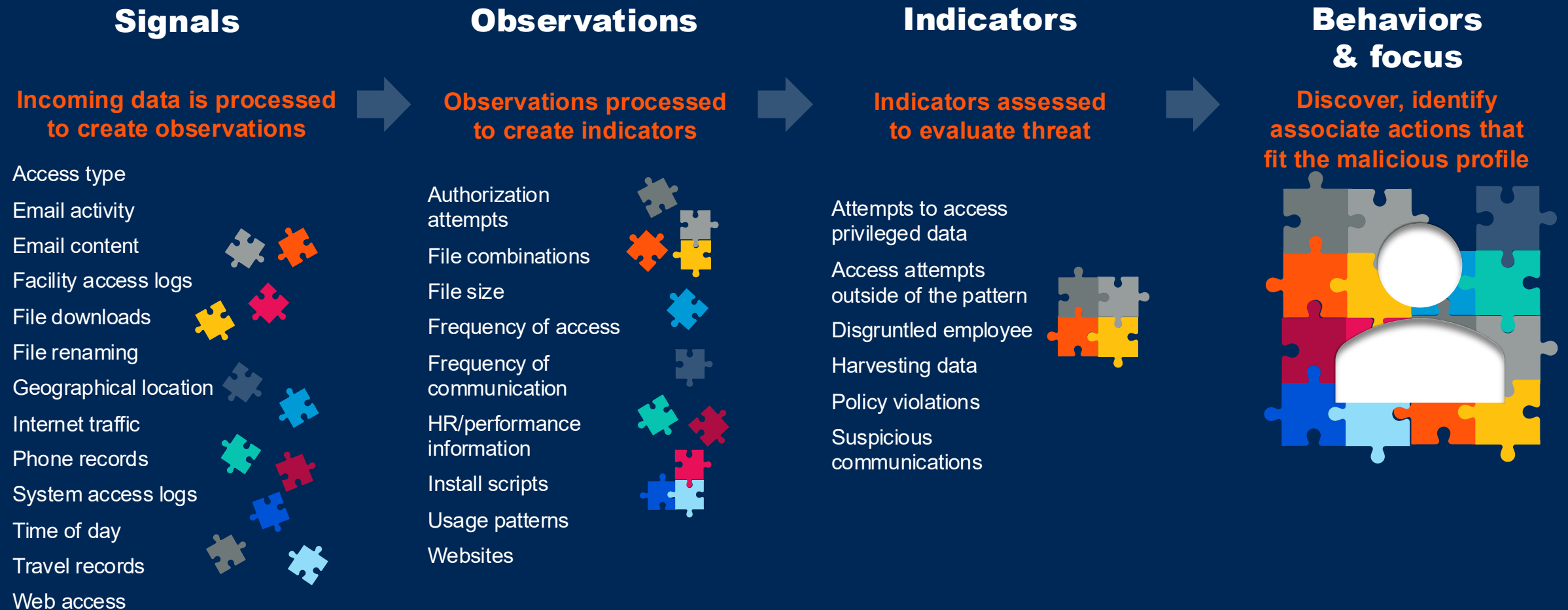
Monitoring:

Any technique or technology used to collect data from IT assets. Monitoring is asset-centric.

Surveillance:

The overt or covert use of monitoring in pursuit of comprehensive awareness of activities of a defined person or group. Surveillance is people-centric in its focus.

Monitoring ≠ Surveillance



Balancing Data Security & Privacy

- Provide transparency.
- Monitor key data loss channels.
- Automate violation notifications.
- Don't collect everything on everyone.
- Control access to collected data.



Insider Risk Management — Cost Control Benefits

“If we see early warning signs, we’d like to be able to intervene before they make a bad decision, and we end in a scenario where we need to terminate an employee. The path to termination is expensive, reparation is preferred.”

CISO, Global Investment Bank



CAUTION

Insider risk is not productivity monitoring

That is an HR/people management function and should not be delivered by the group responsible for security.

Implement the C.A.R.E. Model

Contain



Occurs at a user, network or device level to stop further exposure while security investigates

- Conditional access controls
- Disable USB
- Stop local sync apps
- Network contain device
- Lock Device

Assess



Assess and address a potential data exposure event

- Review activities
- Evaluate activity's potential business risk
- Baseline behaviors

Resolve



Remediate a data exposure event

- Require action from user
- Escalate to manager
- Escalate to HR
- Escalate to legal

Educate



Reduces future exposure by changing user behavior

- Assign targeted micro learning
- Send policy for acknowledgment

Proactive Insider Risk Response Activities

- Immediate end user notices of improper data handling or policy violation.
- Link to microlearning.
- Link to applicable policy for attestation.
- Automatic escalation to manager (for repeat offenders).
- Tracking and trending of activities.

Talk to Gartner



Andrew Bales
Principal Analyst



Paul Furtado
Vice President, Analyst



Brent Predovich
Principal Analyst



Michael Aldridge
Sr. Director Analyst

Recommended Gartner Research

To learn more about access to Gartner research, expert analyst insight, and peer communities, contact your Gartner representative or click on “Become A Client” on gartner.com to speak with one of our specialists.

[3 Actions to Maximize the Success of an Insider Risk Management Program](#)

Brent Predovich and Michael Aldridge

[Market Guide for Insider Risk Management Solutions](#)

Brent Predovich

[Strategies for Midsize Enterprises to Mitigate Insider Risk](#)

Paul Furtado